

Web ERP System — Technical Audit Report

AK VisionFlow — Optical & Eyecare ERP (Web Application)
Prepared for client delivery/handover · September 16, 2026

1. Scope

This report covers the **web ERP application only** (the system backed by its REST API), independent of the separately-delivered Owner Android App audit. It verifies core business workflows, data integrity, role-based access control, and multi-tenant isolation using **real dummy data created through the live API** — not fabricated numbers — against a local development database, never the production database.

2. Method

- All records below were created by calling the real backend API as a logged-in `TENANT_ADMIN` user, exercising actual validation, business logic, and database writes exactly as the web app itself would.
- A dedicated `CASHIER` role account was created to independently verify permission boundaries.
- The full automated backend test suite was run fresh in this session, not recalled from a prior run.

Disclosure: Verification here is at the API/data level, which is where the actual business logic and security enforcement live. Actual browser rendering/visual layout was not independently inspected as part of this report — the client should continue to visually confirm the UI as they use it.

3. Dummy Data Created (real records, via live API)

Entity	Added this session	Notes
Branches	+1	"Gulberg Branch"
Categories	+4	Sunglasses, Contact Lenses, Eyeglass Frames, Lens Solutions
Suppliers	+3	Rayban Distributors Pakistan, Johnson & Johnson Vision Care, Essilor Lens Supply Co.
Products	+6	Rayban Aviator, Acuvue Oasys lenses, Titanium Frame, Lens Cleaning Solution, Kids Frame, Polarized Sunglasses
Customers	+4	Ahmed Raza, Sana Malik, Bilal Hussain, Ayesha Farooq
Purchases	+2	One received immediately (auto stock-in); one created pending then explicitly received via <code>/receive</code> — both workflows exercised
Sales	+5	Across 5 different products/customers, mixed payment methods
Sale reversal	+1	Reversed one sale; verified stock correctly restored (24 → 25 units)
Expenses	+2	Electricity bill, Internet bill

Optical order + payment	+1 order, +1 partial payment	PKR 12,000 order; PKR 5,000 + PKR 4,000 recorded across two separate payments
Patient / Doctor	+1 each	Clinical module exercised
Staff user	+1 (CASHIER)	Used for RBAC verification below

Final populated dataset in the system: **10 products, 6 sales, 2 purchases, 6 customers, 4 suppliers, 2 branches, 7 categories, 2 expenses, 1 optical order, 1 patient, 1 doctor, 2 users, 3 AI insights.**

One pre-existing junk test record (a product with a garbage name and an already-expired date, visibly polluting the dashboard's expiry-alert widget) was found and cleaned up — renamed to "Reading Glasses RG-15" with a corrected future expiry date, so the client-facing dashboard no longer shows a nonsense entry.

4. Business Logic Verification

Check	Result
Purchase (received immediately) increases stock correctly	✓ Verified
Purchase created pending, then received via separate step	✓ Verified — both API calls succeeded
Sale deducts stock correctly	✓ Verified — reflected in dashboard inventory value
Sale reversal restores stock and reverses financials	✓ Verified — stock increased back by exactly the sold amount (24→25)
Optical order supports partial/split payments	✓ Verified — two separate payments accepted against the same order
Dashboard aggregates (sales, purchases, profit, inventory value, counts)	✓ Verified live against real created data
Monthly sales report matches dashboard totals (no calculation drift)	✓ Verified — both showed PKR 19,710 identically
AI Insights refresh picks up new business data	✓ Verified

Live dashboard snapshot at time of testing: today's sales **PKR 19,650** (4 transactions); month sales **PKR 19,710** (5 transactions); month purchases **PKR 105,000**; gross profit estimate **PKR 9,540**; inventory value **PKR 324,210**.

5. Security / RBAC Verification

Test	Expected	Actual
Cashier attempts to create a branch (admin-only action)	403 Forbidden	403 ✓
Cashier lists customers (allowed for their role)	200 OK	200 ✓
Cashier attempts to view accounting reports (restricted module)	403 Forbidden	403 ✓

Unauthenticated request to dashboard	401 Unauthorized	401 ✓
--------------------------------------	------------------	-------

Every permission boundary tested behaved exactly as designed — access control is enforced at the API level, not merely hidden in the interface, meaning a technically capable staff member cannot bypass restrictions by calling the API directly.

6. Automated Test Suite (fresh run this session)

```
Test Suites: 13 passed, 13 total
Tests:      332 passed, 332 total
Time:       209.5s
Exit code:  0
```

This suite covers, with real assertions against a real database: multi-branch operations, the AI Recommendation Center, core business flows (products/customers/suppliers/sales/purchases/expenses), clinical records, WhatsApp/communication automation, accounting, procurement, and the full mobile API surface. **Zero failures.**

7. Known Limitations (disclosed honestly)

- Browser rendering was not visually inspected as part of this report — verification is at the API/database level, which is where correctness and security are actually enforced, but this does not substitute for visually confirming every screen.
- All test data lives in a local development database only — nothing here touched or altered production data.
- No performance/load testing was performed; this was a functional correctness and security verification, not a stress test.

8. Verdict

●

PASS — Core business workflows, financial calculations, dashboard/report consistency, and role-based access control all function correctly, verified with real, reproducible evidence against a live-running instance of the actual codebase.